

LLMs and Privacy

Lecture 15 — Local Deployments and Text De-identification

Juan F. Imbet

Paris Dauphine – PSL University

June 20, 2026

- 1 The Privacy Imperative in Financial AI
- 2 Privacy Risks in LLM Deployment
- 3 Local and Self-Hosted LLM Deployments
- 4 Text Anonymisation and De-identification
- 5 Privacy-Preserving Training Techniques
- 6 Architectural Patterns for Privacy-Compliant Systems
- 7 Evaluation and Compliance

Why Privacy Is the Binding Constraint

THE BIGGER PICTURE

January 2023: a major bank bans staff from pasting client data into ChatGPT after a leaked memo reveals loan applications, earnings transcripts, and merger term sheets crossing a public API. Weeks later, Samsung source code submitted to ChatGPT is retained for training. **Once data crosses the API boundary, there is no technical mechanism for recall.**

LLMs are useful *because* they absorbed vast text — but absorption plus cloud inference creates a privacy surface finance is poorly equipped to govern.

Four complementary engineering strategies (the spine of this lecture):

- ① Local / self-hosted deployment — remove the external boundary
- ② Text anonymisation — strip sensitive content before the model sees it
- ③ Privacy-preserving training (DP, federated learning) — bound memorisation

What Data Do LLMs Expose? Two Channels

Training channel

Information in the pre-training / fine-tuning corpus is reconstructable from *parameters*.

- Persists after the session ends
- Any user may recover fragments
- Fine-tune on proprietary docs $\Rightarrow$ permanent artefact

Inference channel

Data in *prompts* may be stored, logged, or trained on by the provider.

- Operational; depends on the contract
- Eliminated by on-premise deployment
- Encountered first — no skill needed to exploit it

Memorisation is real and quantifiable

Carlini et al. (2021): a 1.5B-param GPT-2 memorises verbatim sequences — emails, phone numbers, identifiers seen *once*. Larger models memorise more; repeated sequences memorised most. Carlini et al. (2022) formalise

Definition: Memorisation

Memorisation (Def. 15.1)

A language model $\mathcal{M}$ *memorises* a string s if there exists a prompt p such that $\mathcal{M}(p)$ generates s with probability above a threshold $\tau \in (0, 1]$.

- **Exact** memorisation: s reproduced verbatim.
- **Approximate** memorisation: bounded Levenshtein edit distance (min. single-character insert/delete/substitute edits).

UNDER THE HOOD

Why rare sequences get memorised: the next-token objective rewards *generalisable* features for common patterns, but for a rare pattern the only path to low loss is to store the specific sequence. A client name appearing once in a fine-tuning corpus is *memorised*; the word “the” is *learned*. The distinction is, in part, a function of frequency.

Regulatory Landscape: Four Frameworks at Once

Framework	Scope	Key bite for LLMs
GDPR (2016/679)	Personal data of EEA individuals (broadest)	Art. 22 (solely automated decisions), Art. 17 (erasure), Art. 83 fines: higher of EUR 20m / 4% global turnover
CCPA / CPRA	California residents	Right to opt out of <i>sale</i> ; may cover sharing with model providers
MiFID II (2014/65)	Investment services	Record-keeping: 5 yr (services), 7 yr (orders), retrievable
DORA (2022/2554)	ICT third parties (since Jan 2025)	Critical-provider oversight; data lo- cation, audit rights, exit strategy

Compliance $\neq$ privacy

A GDPR-compliant cloud provider can still create client privacy risk; a technically private local model can still fail MiFID II record-keeping.

Assess the frameworks together, against each use case.

The Three Risk Mechanisms

THE BIGGER PICTURE

Privacy risks map onto the *confidentiality* axis of the CIA triad — but through mechanisms unlike a database breach. **No firewall stops membership inference; no encryption stops an LLM from reciting a training example.** Understanding the mechanism is a prerequisite for choosing the mitigation.

- 1 **Training-data memorisation & leakage** — extraction attacks recover rare / repeated sequences from parameters.
- 2 **Inference attacks** — membership and property inference leak information *without* verbatim memorisation.
- 3 **Prompt injection & exfiltration** — adversarial instructions in retrieved / ingested content hijack the model.

Memorisation and Extraction Attacks

Neural LMs compress training data into parameters — but compression is lossy only *in aggregate*. Unusual, repeated, or long examples are retained with high fidelity.

UNDER THE HOOD

Likelihood-ratio extraction (Carlini et al., 2021):

- 1 Generate many long continuations from varied prompts.
- 2 Rank by $\frac{\text{Pr}_{\text{target}}(s)}{\text{Pr}_{\text{reference}}(s)}$ — target vs. a smaller reference model.
- 3 High ratio $\Rightarrow$ disproportionately likely to be training data (the reference has not seen the specific sequence).

Recovered: verbatim emails, phone numbers, names, full PII-bearing examples.

Inference Attacks: Membership and Property

Membership Inference Advantage (Def. 15.2)

For model $\mathcal{M}$ trained on D and adversary $\mathcal{A}$ observing a candidate s :

$$\text{Adv}(\mathcal{A}) = |\Pr[\mathcal{A}(\mathcal{M}, s)=1 \mid s \in D] - \Pr[\mathcal{A}(\mathcal{M}, s)=1 \mid s \notin D]|$$

0 = no discrimination; 1 = perfect discrimination. Basis: models assign higher likelihood to training examples (Shokri et al., 2017).

Financial consequence. A bank fine-tunes on merger targets; an adversary queries each candidate name and reconstructs the **deal pipeline** with above-chance accuracy. Same logic leaks whether a specific credit file was in training.

Property inference extends this to *aggregates* (mean loan size, fraction delinquent) — harder to detect, requires no example-level memorisation.

Prompt Injection and Data Exfiltration

Prompt injection (Perez & Ribeiro, 2022): malicious instructions embedded in processed content override system-level instructions. In RAG, retrieved documents are concatenated into the prompt — whoever controls a document controls instructions.

Two finance-specific exposures

- **Adverse-media screening**: an attacker publishes an article with an injection payload $\Rightarrow$ forces a favourable risk score or leaks the screening criteria.
- **Counterparty document ingestion**: loan applications, due-diligence questionnaires, ISDA agreements carrying embedded instructions.

Mitigations (no complete solution yet): structural separation of trusted vs. untrusted content · output sanitisation · rule-based / constitutional classifiers scanning output before delivery.

Keep Inference Inside the Perimeter

THE BIGGER PICTURE

The simplest way to kill inference-time exfiltration: keep inference on the institution's own infrastructure. For many financial workflows the mix of regulation, contracts, and competitive sensitivity makes on-premise not merely preferable but *mandatory*. Capable open-weight models (2023–2024) made this practically feasible for the first time.

Open-weight = parameters publicly released; inference needs no third-party API call. (Distinct from fully open-source — weights yes, full training code / data often no.) What matters for privacy: **no data crosses an external boundary.**

Open-Weight Models: Llama, Mistral, Phi

Family	Params	4-bit footprint	Niche
Llama 2 / 3	7B–70B	7B: ~8 GB VRAM; 70B: ~40 GB	Baseline capable open weights; multi-GPU at 70B
Mistral 7B	7B	~7B-class	GQA + sliding-window attention; matches Llama 2 13B at lower cost
Phi-3-mini	3.8B	laptop GPU	Curated high-quality data; strong reasoning-per-param; edge / branch

Licences carry compliance obligations

Llama 2 Community License: restricts orgs >700M MAU; derivative names must include “Meta Llama”. **Mistral:** Apache 2.0 — no such restriction. Review licence terms before production.

Infrastructure: On-Premise vs. Private Cloud

On-premise

- + No data leaves the perimeter (prompts, completions, metadata)
- GPU capex; ops burden; less elastic

Private cloud

- Single-tenant / VPC, dedicated HW
- AWS Outposts, Azure Gov, GCP Assured Workloads
- ! DPA must satisfy GDPR Art. 28 & DORA Art. 30

Routing for a commercial bank

A lightweight classifier sorts each request:

- 1 **Public:** no client IDs → cloud API
- 2 **Internal:** internal analysis, no PII → private-cloud single-tenant
- 3 **Client:** names / accounts / txns → on-prem, *no external network*

The classifier trains on internal data, calls no external API. Every routing decision is logged (timestamp + tier).

Performance Trade-offs and Quantisation

The cost of going local is capability: best open weights (2025) $\approx$ GPT-3.5-class; lag GPT-4 on complex reasoning and broad factual recall.

UNDER THE HOOD

Quantisation lowers weight precision (16/32-bit $\rightarrow$ 4-bit).

- **GPTQ** (Frantar et al., 2022): block-wise 2nd-order reconstruction using the Hessian; hours; needs a GPU.
- **AWQ** (Lin et al., 2023): $\sim 1\%$ of weights are *salient* (large activations). Protect them with a per-channel scale; quantise the rest uniformly. Minutes; no GPU needed.

Similar final perplexity. **The quant step uses only a small public calibration set — no client data, no added privacy risk.**

Memory at 4-bit

7B $\approx$ **3.5 GB** (less than a video game) · 13B $\approx$ 6.5 GB — fits a high-end

When Local Deployment Is Not Enough

THE BIGGER PICTURE

When inference must pass through external systems, the alternative is to remove or obscure sensitive information *before* the text reaches the model. The technique — de-identification — comes from clinical informatics; finance swaps diagnoses for client names, account numbers, LEIs, and trading positions.

The challenge: sensitive data sits in *prose*, not labelled fields — a loan officer's narrative, call notes, an analyst's draft. Removing a name without context breaks intelligibility; replacing it must be *consistent* so co-references stay coherent.

NER for Sensitive Financial Data

Modern NER = pre-trained transformer encoders, fine-tuned; $F1 > 0.90$ on standard entity types (person, org, location, date, money) in well-edited English.

Finance adds entity types general NER misses — detected by regex or a fine-tuned NER layer:

- Account IDs: IBAN, SWIFT / BIC, account numbers
- Securities: ISIN (12-char), CUSIP, tickers
- Legal entities: LEI (20-char), registration numbers
- Regulatory: passport, national ID, tax ID

Production pipeline = two layers (spaCy, Honnibal & Montani 2017)

Learned model for prose entities (names, orgs, locations) + **rule-based matcher** for structured identifiers (IBAN, ISIN, LEI).

Worked NER Example

“The credit committee reviewed the application of Antoine Dupont (NIF: 12345678A) for a mortgage of EUR 320,000 on the property at 4 Avenue des Champs-Élysées, Paris 75008, with IBAN FR76 3000 6000 0112 3456 7890 189.”

Span	Type	Method
Antoine Dupont	PERSON	Learned model
12345678A	TAX_ID	Rule (NIF pattern)
EUR 320,000	MONEY	Learned model
4 Avenue des Champs-Élysées, Paris 75008	ADDRESS	Learned model
FR76 3000 6000 0112 3456 7890 189	IBAN	Rule (IBAN pattern)

After masking: *“... application of [PERSON_001] (NIF: [TAX_ID_001]) for a mortgage of [MONEY_001] on the property at [ADDRESS_001], with IBAN [IBAN_001].”* — interpretable for summarisation, contains no PII.

Three Anonymisation Strategies + k -Anonymity

Strategy	What it does	Trade-off
Masking	Typed placeholder [PERSON_001]	Lossless structure; discards value
Generalisation	Less specific value (75008 → Paris; EUR 320k → EUR 250–500k)	Keeps statistical content
Suppression	Remove span entirely	Use when type itself is sensitive; can break coherence

k -Anonymity (Def. 15.3, Sweeney 2002)

$\mathcal{D}$ satisfies k -anonymity on quasi-identifiers $\mathcal{Q}$ if every record is indistinguishable from $\geq k - 1$ others when restricted to $\mathcal{Q}$. For text: any output could plausibly come from $\geq k$ individuals. Masking trivially gives

Pseudonymisation, Tokenisation, Re-identification

Pseudonymisation: replace each entity with a realistic *fake* surrogate (“Marie Leclerc” for “Antoine Dupont”), consistent across the document.

- + Reads natural — LLM does not detect placeholders and degrade to generic output
- The mapping table is a **key**: GDPR Recital 26 treats pseudonymised data as *protected*, *not anonymised*. Hold the key separately, access-controlled, encrypted at rest.

Format-preserving tokenisation: replace with a same-format token (valid-but-fake IBAN). Standard in PCI-DSS; now in LLM pipelines — data *looks* real without being real.

Contextual re-identification

Even with all entities removed, a unique combination of dates, amount-ranges, and product types may match one client. Risk $\propto$ adversary background knowledge $\mathcal{K}$, which *grows over time*. $\Rightarrow$ re-assess anonymisation adequacy on a periodic cycle, especially for long-lived archives.

Bounding What the Model Memorises

THE BIGGER PICTURE

Anonymisation guards the *inference* channel. This section guards the *training* channel: limiting how much sensitive information becomes permanently embedded during fine-tuning. Two complementary techniques — **differential privacy** bounds per-example contribution; **federated learning** keeps data in place.

Differential Privacy: The Definition

(ϵ, δ) -Differential Privacy (Def. 15.4, Dwork & Roth 2014)

A randomised $\mathcal{M}$ is (ϵ, δ) -DP if for all adjacent datasets D, D' (differing in one record) and all output sets S :

$$\Pr[\mathcal{M}(D) \in S] \leq e^\epsilon \Pr[\mathcal{M}(D') \in S] + \delta$$

- $\epsilon \geq 0 = \text{privacy budget}$ (smaller = more private)
- $\delta \geq 0 = \text{failure probability}$; pure DP has $\delta = 0$

Intuition. An adversary observing the output cannot confidently tell whether any record was in the input. Log-odds of distinguishing D from D' are bounded by ϵ (exactly, with probability $1 - \delta$).

The Gaussian Mechanism and DP-SGD

Gaussian Mechanism (Thm. 15.1)

For f with ℓ_2 -sensitivity $\Delta_2 f = \max_{D, D'} \|f(D) - f(D')\|_2$:

$$\mathcal{M}(D) = f(D) + \mathcal{N}(0, \sigma^2 I_d), \quad \sigma = \frac{\Delta_2 f \cdot \sqrt{2 \ln(1.25/\delta)}}{\varepsilon}$$

is (ε, δ) -DP for $\varepsilon, \delta \in (0, 1)$.

UNDER THE HOOD

DP-SGD (Abadi et al., 2016) — three changes to SGD:

- 1 *Per-example gradients* g_i (not minibatch sum).
- 2 *Clip*: $\hat{g}_i = g_i / \max(1, \|g_i\|_2 / C)$ — bounds sensitivity to C .
- 3 *Noise*: add $\mathcal{N}(0, \sigma^2 C^2 I)$ to the clipped sum before the update.

Budget tracked by the **moments accountant** / Rényi-DP — tighter than basic composition.

Privacy–Utility Trade-off and Composition

The cost of DP-SGD is utility. Noise slows convergence.

- $\epsilon = 1$: strong privacy, larger utility cost
- $\epsilon = 10$: weak privacy, small cost

Accuracy rises with ϵ and *saturates* toward the non-private baseline.

LoRA / adapters pair well with DP-SGD: fewer trainable params $\Rightarrow$ lower sensitivity $\Rightarrow$ less noise.

Composition (Prop. 15.1)

Sequential: $(\epsilon_1 + \epsilon_2, \delta_1 + \delta_2)$.

Advanced, k steps:

$$\epsilon' \approx \epsilon \sqrt{2k \ln(1/\delta')}$$

Operational implication

Every DP fine-tune *spends* budget. Plan cumulative loss across runs; once exhausted, further training violates the guarantee — requiring a fresh model or a new budget allocation.

Federated Learning: FedAvg

Different threat: data centralisation. Data-residency rules may forbid moving client data across a jurisdiction — even within one institution.

Federated Averaging (Def. 15.5, McMahan et al. 2017)

K clients hold D_k (n_k examples, $n = \sum n_k$). Minimise $F(\theta) = \sum_k \frac{n_k}{n} F_k(\theta)$. Each round t : selected clients init with θ^t , run E local steps, return Δ_k^t . Server aggregates:

$$\theta^{t+1} = \theta^t + \sum_{k \in S_t} \frac{n_k}{\sum_{j \in S_t} n_j} \Delta_k^t$$

Guarantee & limit: the aggregator sees only *updates*, never raw data $\Rightarrow$ data-residency satisfied. But updates leak via **gradient inversion** — combine with *local* DP-SGD for both guarantees.

Finance use cases: (1) multi-bank joint fraud / AML model without sharing data; (2) cross-border improvement of a single global model.

Privacy-Aware RAG

RAG leaks at three points: ingestion (embed & store), retrieval (query embedding reaches the vector DB operator), inference (retrieved docs sit beside user data).

The systematic fix

- **Ingestion:** anonymise *before* embedding; store only the anonymised version; keep the mapping in an access-controlled store.
- **Retrieval:** compute embeddings with a *local* model — query never leaves the network.
- **Inference:** scan retrieved chunks for residual PII before prompting.
- **Access control:** row-level security — each chunk carries an ACL; retrieval is filtered by the user's clearance.

Why access control matters: a junior analyst must not retrieve merger-target docs via an indirect question to the assistant.

Audit Trails and Encrypted Pipelines

Regulators expect full reconstruction of any client-affecting decision: *who* asked, *what* was retrieved, *what* was asked / answered, *what* action followed.

Privacy-aware audit logging

Logging full prompt + completion is the most complete record — but creates a *secondary* PII store under GDPR retention + DORA resilience. Better: log a **hash** of the prompt (integrity, not content) plus structured metadata — user ID, clearance, document IDs, model version, response time, outcome — to an *immutable* store.

Encryption end-to-end: at rest, in transit, ideally during inference.

- *Homomorphic encryption*: compute on ciphertext — infeasible overhead for transformer inference today.
- *Confidential computing* (TEE: Intel TDX, AMD SEV): practical; blocks even the cloud operator during processing.

Measuring Privacy Leakage Empirically

THE BIGGER PICTURE

Verify privacy — do not take it on faith from the training algorithm. Three standard quantitative tests, run after every fine-tune.

- ➊ **Membership inference AUC:** hold out fine-tuning docs as negatives; run the likelihood-ratio attack; AUC of distinguishing members from non-members. $0.5 = \text{perfect privacy}$; $1.0 = \text{total failure}$. < 0.6 **commonly acceptable.**
- ➋ **Verbatim extraction rate:** insert “canary” sensitive strings; measure the fraction recovered. DP fine-tuning $\Rightarrow$ near-zero.
- ➌ **Property inference accuracy:** train a meta-classifier on shadow models to infer an aggregate property; compare to a random baseline.

Compliance Checklist (Selected Rows)

Obligation	Source	Mitigation	Evidence
Restrict automated decisions	GDPR Art. 22	Human-in-the-loop review	Workflow docs
Right to erasure	GDPR Art. 17	Exclude subject from fine-tune; use retrieval	Architecture docs
Data minimisation	GDPR Art. 5	Anonymise before embed; log hashes	Pipeline design
DPIA (high risk)	GDPR Art. 35	Conduct before deployment	Signed DPIA
ICT third-party contract	DORA Art. 30	DORA-compliant DPA	Signed contract
Record-keeping	MiFID II	Immutable audit trail	Log samples
Model risk mgmt	SR 11-7 / ECB	Model card, benchmarks, oversight	Model docs

A DPIA (GDPR Art. 35) must precede any LLM deployment processing

Lecture 15 Summary: Mitigations by Threat

Five strategies, complementary — apply *all* in production

Threat	Mitigation
Inference-channel exfiltration	Local / private-cloud deployment
Input disclosure via prompt	Text anonymisation / de-identification
Training-channel memorisation	DP-SGD during fine-tuning
Data-residency violation	Federated learning
Prompt injection / access failure	Privacy-aware RAG + audit logging

The residual gap

Right to erasure (GDPR Art. 17): excluding a subject from future fine-tuning is easy; *removing* already-memorised information from a deployed model — **machine unlearning** — is an open research problem, not a solved control. Re-measure residual exposure (MI-AUC, canary rate) on a fixed cadence.

APPENDIX

Extended Derivations, Internals, and Edge Cases

Extra / optional material — beyond the core lecture.

Proposition 15.1 (full statement)

For k mechanisms each (ε, δ) -DP, the composite is $(\varepsilon', k\delta + \delta')$ -DP for any $\delta' > 0$ with

$$\varepsilon' = \varepsilon \sqrt{2k \ln(1/\delta')} + k\varepsilon(e^\varepsilon - 1).$$

For small ε ($e^\varepsilon - 1 \approx \varepsilon$) the second term is $O(k\varepsilon^2)$, often negligible vs. the first ($\Rightarrow$ the cited $\varepsilon' \approx \varepsilon \sqrt{2k \ln(1/\delta')}$).

Proof sketch. Basic composition uses post-processing immunity: any function of a DP output keeps the guarantee. Chain the two per-mechanism bounds via a union argument $\Rightarrow (\varepsilon_1 + \varepsilon_2, \delta_1 + \delta_2)$. The advanced bound follows from the moments accountant tracking the Rényi divergence $D_\alpha(P \| Q) = \frac{1}{\alpha - 1} \log \sum_x P(x)^\alpha Q(x)^{1-\alpha}$ between output distributions on D, D' rather than the multiplicative distance.

Appendix B — AWQ vs. GPTQ Internals

UNDER THE HOOD

The 16→4-bit error is *not uniform*. **AWQ**'s insight: $\sim 1\%$ of weights are salient (large activation magnitudes); aggressive quantisation of these causes large output errors. AWQ finds them from activation statistics on a small calibration set, then applies a per-channel *scale* transformation that protects them without raising bit width; the other 99% go uniform 4-bit with negligible loss.

GPTQ instead solves a block-wise reconstruction per weight matrix, minimising quantisation error given the Hessian of outputs w.r.t. weights.

Similar final perplexity; AWQ is faster (minutes vs. hours, 7B) and needs no GPU.

Appendix C — Re-identification as Inference

Model re-identification as an inference problem: the adversary observes the anonymised document $\hat{d}$ and uses prior knowledge $\mathcal{K}$ to form

$$\mathcal{P}(\text{individual} \mid \hat{d}, \mathcal{K}).$$

- Posterior concentrated on one individual $\Rightarrow$ re-identification trivial.
- Posterior uniform over a large set $\Rightarrow$ re-identification infeasible.

Assessment by simulation: apply the pipeline, then attempt re-identification using the institution's *own* databases as $\mathcal{K}$. Success $\Rightarrow$ pipeline insufficient; strengthen generalisation / suppression. Failure on all test cases $\Rightarrow$ adequate *for that threat model*. Point-in-time only — $\mathcal{K}$ grows; re-review on a cycle.

Credit analyst query: “Typical collateral structure for technology-sector LBO loans?”

- 1 Query embedded *locally* by a self-hosted model.
- 2 Top-5 chunks retrieved, filtered to the analyst’s authorised set (policy docs, sector reports, anonymised historical loan files).
- 3 Chunks scanned for PII — none (pre-anonymised at ingestion).
- 4 Local LLM generates, citing retrieved content.
- 5 Logged: timestamp, user ID, *query hash* (not the query), document IDs, model version → immutable audit store.

Result: no client-identifying information enters the prompt; no data crosses an external boundary.